

Compliance Handbook: GDPR, Vietnam PDPA & Regional Regulations

Data Protection Compliance Requirements & Procedures | DPO Office | January 2026

1. Regulatory Landscape Overview

TechViet Solutions operates in a complex regulatory environment due to the nature of our products (processing customer communications) and our customer base (enterprises in Vietnam and Southeast Asia). This handbook provides comprehensive guidance on the data protection regulations that affect TechViet's operations and the specific compliance requirements for each regulation. As of January 2026, the following regulations apply to TechViet's data processing activities: Vietnam's Decree 13/2023/ND-CP on Personal Data Protection (Vietnam PDPA): this decree, which took full effect on July 1, 2023, establishes comprehensive personal data protection requirements for all organizations processing data of Vietnamese individuals. It introduces concepts similar to the GDPR, including data subject rights, data processing principles, data protection impact assessments, and cross-border data transfer restrictions. Of particular relevance to TechViet: the decree requires that certain categories of personal data (known as 'important data' and 'core data') must be stored within Vietnam's territorial borders. The Ministry of Public Security is the enforcement authority, and penalties can include fines of up to VND 100 million for organizations and personal liability for data controllers. European Union General Data Protection Regulation (GDPR): although TechViet is headquartered in Vietnam, the GDPR applies to our processing of personal data of EU residents. This is relevant because 3 of our enterprise customers are European companies operating in Vietnam, and their employees (some of whom are EU citizens) interact with the ChatAssist platform. Under the GDPR's territorial scope (Article 3), TechViet acts as a data processor for these customers' employee data, requiring a Data Processing Agreement (DPA) with each customer and compliance with GDPR processor obligations including data breach notification within 72 hours, maintaining a Record of Processing Activities, and implementing appropriate technical and organizational security measures. The potential penalties under GDPR are substantial: up to €20 million or 4% of global annual turnover, whichever is higher. Singapore Personal Data Protection Act (PDPA): one of our enterprise customers is headquartered in Singapore and uses ChatAssist to serve their Singaporean customer base. This brings the Singapore PDPA into scope, which requires consent for data collection, purpose limitation, and notification to the Personal Data Protection Commission (PDPC) for data breaches. Thailand's Personal Data Protection Act (PDPA): two enterprise customers operate in Thailand, requiring compliance with Thailand's PDPA which is modeled on the GDPR and includes similar data subject rights and cross-border transfer requirements.

2. Data Classification and Handling Requirements

TechViet's data classification framework categorizes all data into four levels based on sensitivity and regulatory requirements. Every data element processed by TechViet must be classified according to this framework, and the classification determines the technical and procedural controls that must be applied during storage, processing, transmission, and disposal. Level 1 — Public Data: information that is intended for public disclosure and would cause no harm if disclosed without authorization. Examples: TechViet's published product documentation, public blog posts, press releases, and information available on the

company website. Controls: no specific controls required beyond basic integrity protection (to prevent unauthorized modification). Level 2 — Internal Data: information that is not intended for public disclosure but would cause only limited harm if disclosed without authorization. Examples: internal process documentation, organizational charts, non-sensitive project plans, meeting notes, and aggregated (non-personal) business metrics. Controls: access restricted to TechViet employees and authorized contractors. Stored on TechViet-managed systems with standard security controls. Encryption in transit (TLS 1.2+) required. Encryption at rest recommended but not mandatory. Level 3 — Confidential Data: information whose unauthorized disclosure could cause significant harm to TechViet, its customers, or individuals. This is the most common classification for data processed by the ChatAssist platform. Examples: customer conversation content, customer configuration data, employee personal information (excluding sensitive categories), financial data, source code, security assessment results, and vendor contracts. Controls: access restricted on a need-to-know basis with role-based access control (RBAC). Encryption in transit (TLS 1.3 required) and at rest (AES-256) mandatory. Data must be stored in approved locations (see Section 3 for cross-border requirements). Backup copies must be encrypted. Access logs must be maintained for at least 12 months. Data disposal must follow the approved data destruction procedure (cryptographic erasure for electronic data, cross-cut shredding for physical media). Level 4 — Restricted Data: the most sensitive category, whose unauthorized disclosure could cause severe harm to individuals or constitute a legal violation. Examples: government-issued identification numbers (CCCD/CMND), biometric data, health records, financial account numbers, authentication credentials, cryptographic keys, and any data classified as 'core data' under Vietnam's Decree 13/2023/ND-CP. Controls: all Level 3 controls plus additional requirements: access requires explicit approval from the Data Protection Officer (DPO), multi-factor authentication required for all access, all access events are logged with real-time alerting for anomalous patterns, data must not be copied to personal devices or unsecured locations, screen capture and printing are restricted in applications handling Level 4 data, and a Data Protection Impact Assessment (DPIA) must be completed before any new processing of Level 4 data. Cross-border transfer of Level 4 data requires specific legal mechanisms (see Section 3).

3. Cross-Border Data Transfer Requirements

Cross-border data transfer is one of the most complex areas of data protection compliance, with different regulations imposing different requirements. This section details the legal mechanisms and procedures required for each applicable regulation when TechViet needs to transfer personal data outside the country of origin. Vietnam Decree 13/2023/ND-CP: Article 25 requires that the transfer of personal data of Vietnamese citizens outside Vietnam must be conducted only when: the data subject has given specific consent to the cross-border transfer (separate from the general processing consent), a Data Protection Impact Assessment has been completed and filed with the Ministry of Public Security, the receiving country or territory has adequate data protection standards (as determined by the Ministry of Public Security — the adequacy list has not yet been published as of January 2026, so currently all cross-border transfers require the consent and DPIA mechanisms), and for 'important data' and 'core data', a copy must be retained within Vietnam. TechViet's implementation: for ChatAssist data, the primary storage is in the AWS ap-southeast-5 (Hanoi) region, ensuring Vietnamese data residency. Cross-border transfer occurs only when: the customer explicitly requests it (e.g., a European customer wanting data replicated to the EU region), or for technical operations where data processing requires cross-region traffic (e.g., AI model inference may route through the ap-southeast-1 Singapore region for GPU availability). In the latter case, the data is processed in-memory and not persisted outside Vietnam. GDPR: Chapter V of the GDPR restricts transfers of personal data outside the European Economic Area (EEA) unless an appropriate safeguard is in place. TechViet uses the following mechanisms for GDPR-regulated data: Standard Contractual Clauses (SCCs): all DPAs with European customers include the European Commission's Standard Contractual Clauses (adopted June 2021), specifically the Module 2 (Controller to Processor) clauses. These clauses obligate TechViet to apply data protection standards equivalent to the GDPR and

allow the European customer to audit TechViet's compliance. Transfer Impact Assessment: for each data transfer to Vietnam, TechViet has conducted a Transfer Impact Assessment (TIA) evaluating the legal framework in Vietnam and any government access risks. The TIA concludes that Vietnam's Decree 13/2023/ND-CP provides a level of protection that, while not yet recognized as adequate by the European Commission, is substantially aligned with GDPR principles when supplemented by the contractual safeguards in the SCCs.

4. Data Subject Rights Implementation

Both the GDPR and Vietnam's Decree 13/2023/ND-CP grant individuals specific rights regarding the processing of their personal data. TechViet has implemented processes and technical mechanisms to fulfill these rights within the required timeframes. The following rights are implemented: Right of Access (GDPR Article 15, Decree 13 Article 9): individuals can request a copy of all personal data that TechViet processes about them. For ChatAssist end-users, this request is typically submitted through the customer (data controller), who then uses the ChatAssist Admin API's data export endpoint (POST /v2/admin/users/{user_id}/data-export) to generate a machine-readable export in JSON format containing all conversation data, user profile data, and feedback data associated with the user. The export is encrypted and delivered via a secure download link valid for 72 hours. For TechViet employees requesting access to their own data, the request is submitted through the HR Portal and processed by the DPO within 7 business days. Right to Erasure (GDPR Article 17, Decree 13 Article 16): individuals can request deletion of their personal data, subject to certain exceptions (legal obligation, public interest, exercise of legal claims). TechViet's implementation uses a two-phase deletion process: Phase 1 (immediate) — the user's personal identifiers are replaced with irreversible pseudonyms in all operational databases (PostgreSQL, Redis, Elasticsearch), and the user's account is deactivated. Conversation content is retained but de-identified. Phase 2 (within 30 days) — a background job removes the user's data from all backup systems, analytics databases, and ML training datasets. The job produces an audit log documenting every system from which data was removed, which is retained for 3 years as evidence of compliance. The DPO signs off on every erasure completion. Right to Data Portability (GDPR Article 20): individuals can request their data in a structured, commonly used, machine-readable format and have it transmitted to another controller. TechViet uses the same data export mechanism as the Right of Access, with the addition of a direct transfer option where the export can be sent via API to a destination specified by the customer. The export format follows the schema.org/ConversationThread vocabulary for interoperability with other chat platforms.

5. Breach Notification Procedures

A personal data breach is defined as a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data transmitted, stored, or otherwise processed. TechViet's breach notification obligations vary by regulation but converge on the need for rapid detection, assessment, and communication. Vietnam Decree 13/2023/ND-CP: the data controller (TechViet for employee data; our customer for end-user data) must notify the Ministry of Public Security's Department of Cybersecurity within 72 hours of becoming aware of a breach affecting personal data of Vietnamese citizens. The notification must include: a description of the nature of the breach, the categories and approximate number of data subjects affected, the likely consequences, the measures taken to address the breach, and the contact details of the DPO. Data subjects must also be notified without undue delay if the breach is likely to result in a high risk to their rights. GDPR: the data controller must notify the relevant supervisory authority within 72 hours (Article 33), and data subjects without undue delay if the breach is likely to result in a high risk (Article 34). As a data processor for European customers, TechViet's obligation is to notify the controller (our customer) without undue delay after becoming aware of a breach (Article 33(2)). Our DPAs commit to a 24-hour notification window, which is more stringent than the GDPR

requirement but aligns with customer expectations. TechViet's breach response process follows a four-phase approach: Phase 1 — Detection and Containment (0-4 hours): upon detection of a potential breach (via security monitoring, employee report, or external notification), the Security Operations team performs initial triage to determine the scope and severity. If a breach is confirmed, immediate containment actions are taken (e.g., disabling compromised accounts, isolating affected systems, revoking exposed credentials). Phase 2 — Assessment (4-24 hours): the DPO and Security team conduct a detailed assessment to determine: the type of data affected and its classification level, the number of data subjects affected, the geographic scope (which jurisdictions' data was involved), the likely cause, and the risk to data subjects. Phase 3 — Notification (24-72 hours): based on the assessment, the DPO determines which regulators, customers, and data subjects must be notified, and coordinates the communications. Regulatory notifications are prepared using pre-drafted templates for each jurisdiction. Customer notifications are sent via the designated contact in each customer's DPA. Phase 4 — Remediation and Review (1-30 days): the root cause is fully investigated, remediation actions are implemented, and a lessons-learned review is conducted. The DPO updates the Record of Data Breaches and presents findings to the executive team.